ĐẠI HỌC QUỐC GIA TP HCM
ĐẠI HỌC KHOA HỌC TỰ NHIÊN

KHOA CÔNG NGHỆ THÔNG TIN

GIAI ĐOẠN 1: PHÂN TÍCH VÀ XÁC ĐỊNH YÊU CẦU

Thái Hữu Thọ - 22127400

GIÁO VIÊN HƯỚNG DẪN
Nguyễn Đình Thúc
Ngô Đình Hy

January 27, 2026

Mục lục

1 Giới thiệu chủ đề được chọn **3**
1.1 Lý do chọn đề tài 3
1.2 Mục tiêu của đồ án 3

2 Đặc tả Yêu cầu Chức năng **3**

3 Đặc tả Yêu cầu phi chức năng **4**
3.1 Tiêu chuẩn Bảo mật 4
3.2 Tiêu chuẩn hiệu năng và tính khả dụng 4

1 Giới thiệu chủ đề được chọn

1.1 Lý do chọn đề tài

Trong bối cảnh tài chính số hiện nay, các ứng dụng ví điện tử và quản lý chi tiêu cá nhân là mục tiêu thường xuyên của các cuộc tấn công mạng. Tuy nhiên, nhiều ứng dụng chủ yếu tập trung vào giao diện và tính năng, trong khi chưa đầu tư đầy đủ cho hệ thống bảo mật lõi (Security Core).

Trên thực tế, việc lưu trữ mật khẩu ở dạng văn bản thô hoặc chỉ sử dụng các hàm băm đơn giản khiến hệ thống dễ bị tấn công từ điển (Dictionary Attack). Ngoài ra, nếu các lệnh giao dịch không được kiểm tra tính mới của yêu cầu (freshness), kẻ tấn công có thể phát lại các gói tin hợp lệ để thực hiện giao dịch trái phép (Replay Attack).

Vì vậy, việc xây dựng một module bảo mật độc lập, có thể tích hợp vào hệ thống hiện có và có khả năng chống lại các hình thức tấn công phổ biến như Dictionary Attack và Replay Attack là cần thiết và phù hợp với yêu cầu thực tế.

1.2 Mục tiêu của đồ án

Đồ án chủ yếu tập trung vào xây dựng module bảo mật chuyên biệt:

- Về kỹ thuật mã hóa:
  - Nghiên cứu và triển khai thuật toán mã hóa đối xứng AES-256-GCM nhằm bảo mật dữ liệu lưu trữ, đồng thời sử dụng thuật toán ECDSA để thực hiện chức năng chữ ký số và xác thực tính toàn vẹn của dữ liệu.
- Khả năng bảo mật
  - Xây dựng cơ chế chống Replay Attack thông qua việc kết hợp số ngẫu nhiên dùng một lần (nonce) và timestamp nhằm đảm bảo tính mới của mỗi yêu cầu giao dịch.
  - Xây dựng cơ chế ngăn chặn Dictionary Attack bằng cách áp dụng kỹ thuật salting và kéo giãn khóa sử dụng thuật toán PBKDF2 trong quá trình lưu trữ và xác thực mật khẩu.
- Phát triển một thư viện mã nguồn (Security Core) bằng ngôn ngữ Python với cấu trúc rõ ràng, cho phép dễ dàng tích hợp và tái sử dụng trong các hệ thống hoặc đồ án quản lý tài chính khác.
- Đối tượng nghiên cứu:
  - Các giao thức và thuật toán mật mã hiện đại.
  - Cơ chế hoạt động và phương pháp phòng chống hai hình thức phổ biến là Replay Attack và Dictionary Attack.
  - Đồ án tập trung vào bảo mật dữ liệu lưu trữ (data-at-rest) và bảo mật giao dịch giữa Client và Database.

2 Đặc tả Yêu cầu Chức năng

Module Security Core phải cung cấp các API để ứng dụng chính gọi tới. Các chức năng bắt buộc bao gồm:

- Sinh khóa và Xác thực
  - Hệ thống phải có khả năng sinh khóa mã hóa từ mật khẩu người dùng kết hợp với 1 chuỗi ngẫu nhiêu.
  - Hê thống phải xác thực được mật khẩu người dùng nhập vào mà không lưu mật khẩu gốc.

- Mã hóa/ Giải mã dữ liệu
  - Hệ thống phải nhận đầu vào là dữ liệu thô (plaintext) và trả về dữ liệu mã hóa (ciphertext) không thể đọc hiểu.
  - Hệ thống phải cảnh báo lỗi nếu dữ liệu đàu vào để giải mã bị thay đổi.
- Ký số
  - Hệ thống phải tự động sinh ra số ngẫu nhiên dùng 1 lần và sử dụng thời gian hiện tại.
  - Hệ thống phải tạo chữ ký số bao trùm lên toàn bộ bộ dữ liệu: Data, nonce, timestamp.
- Kiểm tra tính hợp lệ theo thời gian
  - Hệ thống phải từ chối xử lý nếu thông tin có timestamp cũ hơn 1 phút.
  - Hệ thống phải từ chối nếu Nonce của thông tin đã tồn tại trong bộ nhớ đệm.

3 Đặc tả Yêu cầu phi chức năng

3.1 Tiêu chuẩn Bảo mật

- Hasing: Sử dụng thuật toán PBKDF2-HMAC-SHA256.
  - Số vòng lặp: Tối thiểu 600000 vòng(Theo khuyến nghị OWASP 2023).
  - Độ dài Salt: Tối thiểu 16 bytes (128-bit) sinh ngẫu nhiên an toàn (CSPRNG).
- Encryption: Sử dụng thuật toán AES-256 chế độ GCM (Galois/Counter Mode).
- Signature: Sử dụng thuật toán ECDSA (Elliptic Curve Digital Signature Algorithm). Curve: SECP256R1 (NIST P-256), tốc độ ký và xác thực nhanh hơn RSA, kích thước khóa nhỏ gọn phù hợp lưu trữ cá nhân.

3.2 Tiêu chuẩn hiệu năng và tính khả dụng

- Performance:
  - Thời gian khởi tạo khóa (Login): 0.5s - 1.0s (Đủ chậm để chống Brute-force, đủ nhanh để người dùng không khó chịu).
  - Thời gian xử lý một giao dịch (Ký + Mã hóa): $< 50ms$.
- Reliability: Cơ chế Fail-Secure: Nếu xảy ra bất kỳ lỗi ngoại lệ nào (Exception) trong quá trình mã hóa/giải mã, hệ thống phải dừng lại và từ chối truy cập, không được phép trả về dữ liệu rác hoặc dữ liệu thô.